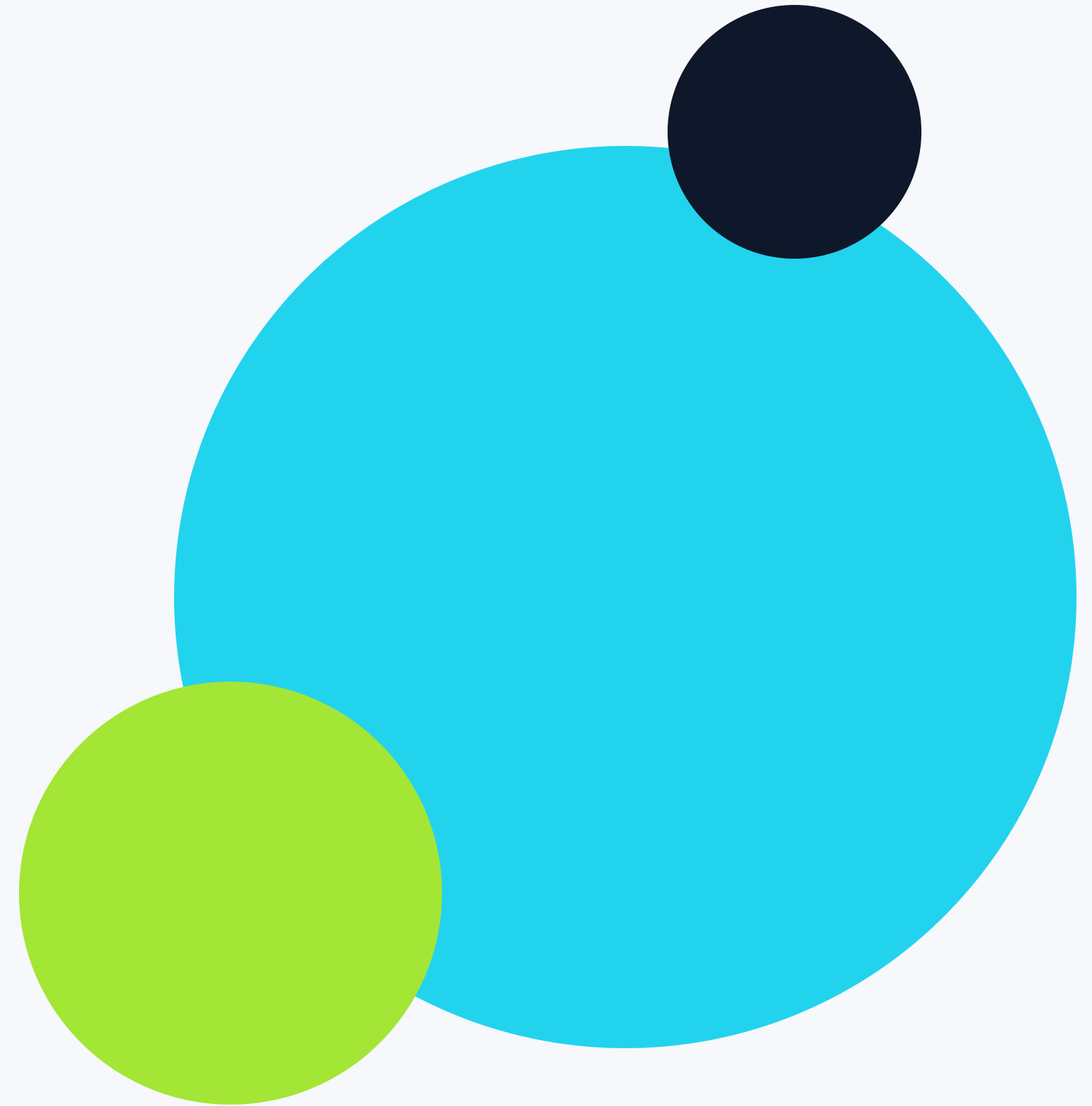


Identity governance

Entitlement, access reviews, PIM y monitoreo. 20
a 25% del examen.



HOY, EN 45 MINUTOS

Una idea por área, doce trampas

5'

Mapa

Cuatro áreas y tres preguntas: quién decide, cuándo pasa, dónde queda el dato.

18'

Trampas

Doce trampas en diez slides. Una frase para recordar cada una.

18'

Kahoot

Diez preguntas del banco M4. Después de cada una, el porqué de cada distractor.

4'

Cierre

Qué preparar para la sesión 5 y dónde están los links.

Cuatro áreas, una idea por área

**20 a
25%**

del examen. El dominio de quién pide, quién aprueba, quién revisa y quién activa.

1 · Entitlement management

Catalogs, access packages, terms of use, connected organizations y el ciclo de vida de externos. Trampas 1 a 5.

2 · Access reviews

Dónde se crean, quién revisa, qué pasa si nadie responde y cuándo se aplica el resultado. Trampas 6, 7 y 8.

3 · Privileged access

PIM para roles de Entra, Azure resources y Groups, más las cuentas break-glass. Trampas 9, 10 y 11.

4 · Monitoring

Logs, diagnostic settings, KQL en Log Analytics, workbooks e Identity Secure Score. Trampa 12.

LAS TRES PREGUNTAS QUE RESUELVEN CASI TODO M4

1 ¿Quién decide?

La policy del paquete dice quién pide y quién aprueba. En la review gana la última decisión. En PIM, las reglas viven en el rol, y en Azure en cada recurso.

2 ¿Cuándo pasa?

El paquete vence y el ciclo de vida limpia al guest. La review toma una foto al inicio y nada cambia hasta el final o hasta Apply. Eligible es acceso JIT.

3 ¿Dónde queda el dato?

La licencia define cuánto guardas, la diagnostic setting a dónde va cada categoría, y cada categoría cae en su propia tabla de Log Analytics.

Quién crea, quién asigna

"Catalog owner trae los recursos, access package manager arma los paquetes, assignment manager solo mete y saca gente."

1

Catalog owner

Trae los recursos y delega.
Necesita **además** permiso sobre el recurso.



2

Access package manager

Crea y edita paquetes y políticas con lo que ya está en el catálogo.



3

Assignment manager

Asigna, quita, ve requests y reprocesa. **No crea paquetes.**



Identity Governance Administrator agrega **apps**, **no grupos**. User Administrator ya no crea catálogos.

Una policy, un público

"Internos y externos no caben en la misma policy: son dos."

POLICY 1 · IN YOUR DIRECTORY

For users, service principals, and agent identities in your directory

- Members, all users (con guests) o specific groups.
- Manager as approver solo existe aquí.

POLICY 2 · NOT IN YOUR DIRECTORY

For users not in your directory

- Specific connected orgs, all configured connected orgs o all users.
- All users crea connected orgs **proposed**: no entran en "All configured". Pide email OTP.

La B2B allow/block list siempre gana: si el dominio no está permitido, no hay invitación ni acceso.

Aprobaciones y el reloj

"En cada stage basta uno; si nadie decide a tiempo, la request se muere y se pide otra vez."

🕒 El reloj de los stages

- 1. Hasta 3 stages. En cada uno decide el primero que responde.
- 2. Cada stage tiene su plazo. Aprobar uno no aprueba el siguiente.
- 3. Sin decisión a tiempo: **Expired**. Se deniega y se pide otra vez.

Quién entra cuando falta alguien

Approver	Cuándo entra
Alternate	El approver no actúa: forward después de N días. Timeout de al menos 4 días.
Fallback	No se encuentra el manager del usuario.
Manager	Solo para usuarios de tu directorio.
Sponsor	Para externos. Se define en la connected org.

Externos: entrar y salir

"Último paquete perdido: bloqueado hoy, borrado en 30 días. La ToU es un PDF que no muere hasta que Conditional Access la pone en el Grant."

Lifecycle of external users

- Default: bloqueo de sign-in y borrado a los 30 días. Con 0 días, borrado ya.
- Se cambia en Control Configurations.
- Solo guests que entraron por entitlement management o convertidos a governed. Se borran **aunque tengan otros accesos**, como un sitio compartido.

Terms of use

- P1 y Conditional Access Administrator. Se hace cumplir **solo con una política de CA**.
- Per-device pide device registrado y no soporta B2B.
- Con re-aceptación, se acepta otra vez cuando expira la sesión. Si rechaza, queda bloqueado.

Dónde se crea y quién revisa

"Grupos y apps en Access reviews, roles en PIM, paquetes en entitlement management.
Fallback solo si hay managers u owners."

Dónde se crea cada review

Qué revisas	Dónde la creas
Grupos y apps	Access reviews
Roles de Entra y de Azure	PIM
Access packages	Entitlement management

Que los group owners creen reviews pide un setting aparte en Access reviews > Settings.

Quién revisa y a quién

- Group owners, selected users or groups, self review o managers.
- Fallback solo con managers u owners. Cuentan los owners del inicio.
- Scope: Guest users only o Everyone. Inactive users hasta 730 días.
- "All Microsoft 365 groups with guest users" solo revisa guests y no deja elegir la acción para denegados.

La review que borra todo

"If reviewers don't respond más auto apply es un botón de borrar: elige con cuidado."

No change	Deja a todos, también a los inactivos.
Approve access	Aprueba a todos, incluidos los inactivos.
Remove access	Quita a todos los no revisados. Con auto apply puede quitar todo el acceso.
Take recommendations	Helper "No sign-in within 30 days": quita inactivos, deja activos.

Trampa 8 · Gana el último

- Varios reviewers: vale la última respuesta. En multi-stage, la etapa posterior sobrescribe.
- Don't know deja el acceso. El deny sale al final o al Stop, y una review detenida no se reinicia.
- Sin auto apply: Review history > Apply. No cambia grupos on-premises ni dinámicos.

PIM: eligible vs active

"Eligible es JIT, time-bound es con fecha de muerte. El ticket es de adorno y el approver no necesita rol."

	PERMANENT	TIME-BOUND
Eligible	JIT, pero nunca vence. Alguien la quita a mano.	JIT y vence sola. El proyecto de seis meses.
Active	Siempre activo y para siempre. La excepción: break-glass.	Activo todo el periodo, sin JIT.

- Las perillas del rol**
- Activation maximum duration: 1 a 24 horas. Ticket: solo informativo.
 - Sin approvers: aprueban PRA y GA activos. En Azure y Groups no hay default.
 - La primera decisión resuelve. 24 horas para aprobar.
 - Método fuerte al activar: authentication context más strength, con CA para todos o los eligible, no para el rol.

PIM fuera de Entra roles

"En Azure, los settings no bajan de la suscripción al resource group. En Groups, el grupo no tiene que ser role-assignable."

PIM for Azure resources

- Settings con Owner o User Access Administrator, por rol y por recurso. **Sin herencia.**
- Sin approvers por default. No hay eligible para service principals ni managed identities.
- Discovery legacy pone a MS-PIM como User Access Administrator y no se deshace.

PIM for Groups

- JIT de member u owner, con dos policies por grupo. **No necesita role-assignable.**
- No aplica a grupos dinámicos ni synced.
- Role-assignable protege credenciales y no acepta grupos anidados activos. Para Exchange o SharePoint, PIM for Entra roles.

Break-glass bien hecha

"La break-glass no espera aprobación: GA active permanent, FIDO2 en la caja fuerte y una alerta que grita en cada sign-in."

Checklist

- ✓ Dos o más, cloud-only en .onmicrosoft.com.
- ✓ Global Administrator **active permanent**, no eligible.
- ✓ Passkey FIDO2 o CBA, distinto al de los admins.
- ✓ Excluidas de CA que bloquea o restringe. Report-only no necesita exclusión.
- ✓ Validar cada 90 días.

La alerta, sobre SigninLogs

```
SigninLogs
| where UserId = "bg1-object-id"
      or UserId = "bg2-object-id"
| project TimeGenerated, UserId,
      IPAddress, ResultType
```

Alert rule con Custom log search y umbral mayor que 0. **Sin filtrar por ResultType**: cuenta éxitos y fallos.

Del log a la respuesta

"Free 7, P1/P2 30, y el upgrade no revive datos. Cada categoría llena su tabla, y el workbook come de Log Analytics."

**Storage account**
Archivo barato y largo.

**Event hub**
SIEM de terceros.

**Log Analytics**
KQL, workbooks y alertas.

Cada categoría cae en su tabla

SignInLogs	AADNonInteractiveUserSignInLogs
AuditLogs	AADServicePrincipalSignInLogs
AADProvisioningLogs	AADManagedIdentitySignInLogs

La diagnostic setting la crea un **Security Administrator** y el destino existe antes.

Identity Secure Score

- Se recalcula cada 24 horas.
- **Risk accepted no suma.** Resolved through third party sí.

BLOQUE 3 · 18 MINUTOS

Kahoot

Diez preguntas del banco M4, 60 segundos cada una. Ganar no es el punto: **el porqué de cada distractor** sí.

kahoot.it

PIN: en vivo

El grupo no sale en el picker

Pat, a catalog owner with no directory role, can't find group SG-Lab in the resource picker. Least privilege fix?

- A Assign Pat the Identity Governance Administrator role
- B Assign Pat the Groups Administrator role
- ☒ C Add Pat as an owner of SG-Lab
- D Add Pat as an access package manager of the catalog

Por qué

Agregar un recurso pide **dos cosas**: ser catalog owner y tener permiso sobre el recurso. Un catalog owner sin rol agrega un grupo solo si es su owner.

A. Identity Governance Administrator agrega apps, no security groups ni Microsoft 365 groups.

B. Funciona, pero es un rol de todo el tenant. No es least privilege.

D. El access package manager usa recursos que ya están en el catalog. No agrega recursos.

Empleados y partners, un paquete

Contoso members request with manager approval; Fabrikam users with sponsor approval. Minimum number of policies?

A One

✓ Two

C Three

D Four

Por qué

Una sola policy **no asigna internos y externos** al mismo paquete. Una policy in your directory con el manager y otra not in your directory con el external sponsor.

A. Una policy tiene un solo público.

C. Tres sería si además quisieras asignación automática o solo directa por admin. No se pide.

D. No hay cuatro públicos distintos en el escenario.

Carol nunca contestó

Two-stage approval, 5 days each. Alice approves stage 1 on day 1. Carol never acts in stage 2. What happens?

- A It's approved, because stage 1 already approved it
- ☒ **It expires (auto-denied) and the user must request again**
- C It's forwarded to Global Administrators
- D It returns to Bob, who didn't respond in stage 1

Por qué

Basta un approver por stage y cada stage tiene su plazo. Si nadie decide a tiempo, la request se deniega sola (Expired) y hay que pedir otra vez.

A. Un stage aprobado no aprueba los siguientes. Todos los stages deben aprobar.

C. No hay forward automático a Global Administrators. Solo alternate approvers, si los configuras.

D. Alice ya resolvió el stage 1. Bob no vuelve a entrar.

Ana pierde su último paquete

Guest Ana joined via access package, then got a shared SharePoint site. Her only package expires (defaults). Result?

- A Nothing, she still has access to a SharePoint site
- B Her guest account is deleted immediately
- ☒ C Blocked from sign-in now, removed after 30 days
- D Stays active until the next access review of the site

Por qué

Al perder su **último** access package, el guest queda bloqueado y se borra a los 30 días, **aunque tenga otros accesos** como un sitio compartido después.

A. El sitio compartido no la salva: Ana entró por entitlement management.

B. El borrado inmediato solo pasa si pones 0 días.

D. Una access review no controla este ciclo de vida.

Revisar a los Global Admins

Auditors want a quarterly review of eligible and active Global Administrator assignments. Where do you create it?

A Access Reviews > Teams + Groups

☒ Privileged Identity Management

C Entitlement management, in an access package policy

D Enterprise applications, on the Microsoft Graph app

Por qué

La tabla "Where do you create reviews?" de Learn: **los roles de Entra y de Azure se revisan desde PIM**. Para roles de Entra, al menos Privileged Role Administrator.

A. Teams + Groups revisa membresía de grupos, no asignaciones de roles.

C. Ahí se revisan asignaciones de access packages.

D. Ahí se revisa quién tiene asignada una app.

Nadie respondió la review

Review with auto apply and the 30-day sign-in helper. No response: inactive users lose access, active keep it. Option?

- A No change
- B Remove access
- C Approve access

☒ Take recommendations

Por qué

Take recommendations aplica lo que recomienda el sistema. Con el helper "No sign-in within 30 days" aprueba a quien entró y deniega a quien no.

A. Deja a todos igual, incluidos los inactivos.

B. Quita a todos los no revisados, también a los activos. Con auto apply puede quitar todo el acceso.

C. Aprueba a todos, incluidos los inactivos.

Alice aprueba, Bob deniega

HR-Files review, two reviewers, auto apply on. Day 2 Alice approves Dan; day 5 Bob denies Dan. What happens to Dan?

- A He keeps membership, because one approval is enough
- B He's removed as soon as Bob submits his decision
- ☒ C He's removed when the review ends or is stopped
- D It's flagged as a conflict for an admin to decide

Por qué

Con varios reviewers **se guarda la última respuesta**, la de Bob. Y el denegado no sale al instante: **sale al terminar la review** o cuando un admin la detiene.

A. No hay regla de "basta una aprobación". Gana la última decisión.

B. El deny no se aplica en el momento. Se aplica al final.

D. No existe un estado de conflicto entre reviewers.

Seis meses, solo cuando se necesite

Helpdesk leads need User Administrator only when needed for a 6-month project, then lose it without cleanup. Assignment?

A Active, permanent

B Eligible, permanent

☒ Eligible, time-bound, ending with the project

D Active, time-bound, ending with the project

Por qué

Eligible: activan el rol solo cuando lo necesitan (JIT). **Time-bound** con fecha de fin: la elegibilidad termina sola al acabar el proyecto.

A. Tendrían el rol siempre activo y para siempre.

B. Nunca vence. Alguien tendría que quitarla a mano.

D. Tendrían el rol activo los seis meses completos, sin JIT.

Owner en RG1 sin aprobación

Owner settings on Sub1 require approval. Kim, eligible for Owner on RG1 in Sub1, activates with no approval. Why?

- A Approval is supported only for Microsoft Entra roles
- ☒ **Subscription role settings aren't inherited by the resource group**
- C The Owner role can't require approval in PIM
- D RG1 wasn't discovered, so PIM ignores its settings

Por qué

Las role settings son **por rol y por recurso**, y lo que configuras en Subscription **no se hereda** en Resource Group. RG1 tiene su propia policy de Owner, sin aprobación.

- A. La aprobación existe en roles de Entra, Azure resources y PIM for Groups.
- C. Owner sí puede pedir aprobación.
- D. Los hijos de un recurso ya manejado entran en PIM. El problema no es el discovery.

La query que no devuelve nada

Diagnostic setting sends only AuditLogs and SignInLogs. How do you get data in AADNonInteractiveUserSignInLogs?

```
AADNonInteractiveUserSignInLogs  
| where TimeGenerated > ago(1d)  
| summarize CountPerIPAddress = count() by IPAddress  
| order by CountPerIPAddress desc
```

✓ Add the NonInteractiveUserSignInLogs category

B Upgrade the tenant from Entra ID P1 to P2

C Add the ServicePrincipalSignInLogs category

D Change ago(1d) to ago(30d)

Por qué

Cada categoría de la diagnostic setting **llena su propia tabla**. SignInLogs llena SigninLogs (interactive). AADNonInteractiveUserSignInLogs solo recibe datos con la categoría **NonInteractiveUserSignInLogs**.

B. P1 ya alcanza para enviar logs a Log Analytics. La licencia no es el problema.

C. Llena otra tabla, la de apps y service principals.

D. Los non-interactive se registran todo el tiempo. El rango de fechas no es el problema.

Antes de la sesión 5: labs y simulacro



Repasa los 10 labs

Guía de labs en imágenes: pasos cortos con capturas de Learn. Los labs 22, 25 y 26 son de este módulo: catalog, access reviews y PIM.



Repasa M4

Vuelve a lo que fallaste hoy en el Kahoot y termina el banco M4 de 40 preguntas, con las 4 queries KQL.



Haz el simulacro

30 preguntas, 7 u 8 por dominio, antes de la sesión 5. En vivo vemos labs en imágenes, estrategia de examen y el simulacro.

Si presentas el examen esta semana: llena el debrief el mismo día. Temas sí, preguntas no.

RECURSOS, TODOS CON LINK

Todo es público y de Microsoft Learn



Study guide y skills outline

Study guide for Exam SC-300



Practice assessment gratis

Practice Assessment SC-300



Learning path de M4

Identity governance strategy (4 módulos)



Entitlement management

Plan and implement entitlement management (módulo)



Privileged access

Plan and implement privileged access (módulo)



Labs oficiales del curso

SC-300 Labs index en GitHub